

Introduction to Digital Certificates

Class 1 of a Certificate Course

Presenter: Charles Mills

charlesm@mcn.org

© 2026 Charles Mills Consulting, LLC

2

About the Presenter

Charles has been writing mainframe software for longer than he cares to admit. He developed security software for eight years at CorreLog, where he authored the zDefender and SyslogDefender products which were acquired by BMC. He is currently the Chief Development Officer for Cloud Compiling and also does freelance project-oriented development.

He has a PhD in certificate technology from the University of Hard Knocks.



4

Overview of the four webinars

1. Introduction to Digital Certificates

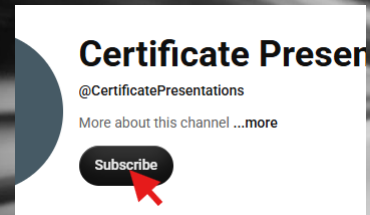
What are certificates and what do they do? What's in a certificate? How does a certificate sign a certificate? The Chain of Trust. Certificate Issuance, Renewal and Revocation. A Very Brief Introduction to Certificate Management .

2. The TLS Protocol – An Inside View

3. Introduction to Certificate Management with RACF

4. Some Advanced Digital Certificate Topics

X.509 and ASN.1. Base 64. Quantum. The coming 47-day renewal crisis and ACME. Client certificates. Cross-signing. Code signing. Validated boot.



<https://www.youtube.com/channel/UC-d8Tscv3tmS2AfIPvzRPhA>
<https://bit.ly/3TZcTz4>

<https://bit.ly/3TZcTz4>

5

Handouts

Are you looking only at these handouts, not the recorded webinar? May I ask a favor? The webinar IS the recorded webinar. The handouts are just ... the handouts for the webinar. I think you will get more out of your time if you watch the recorded webinar on YouTube.

Thanks!

<https://www.youtube.com/channel/UC-d8Tscv3tmS2AfIPvzRPhA>

<https://bit.ly/3TZcTz4>



7

Agenda

What are certificates and what do they do?

What's in a certificate?

How does a certificate sign a certificate?

Chain of Trust

Certificate Issuance, Renewal and Revocation

A Very Brief Introduction to Certificate Management

Some Certificate Problems

8

What is a certificate and what do certificates do?

9

What is a certificate?

An Internet standard (ITU standard x.509)

A digital certification of the authenticity of something:

- A Web server (or TN3270, CICS, etc.)
- Another certificate
- A piece of software

Not sensitive – sent out unencrypted to anyone who connects

A significant pain for many z/OS sysprogs

“Just a file” – typically about 2 or 3 kB

A pretty package wrapped around a public key



[This Photo](#) by Unknown Author is licensed under [CC BY-SA-NC](#)

10

Why certificates?

1977: Rivest, Shamir and Adelman invented digital certificates as part of their solution to the problem of secret key distribution

1994: Netscape – first to commercialize the Internet – perceived the Web not secure enough for e-commerce and invented SSL

1998: Netscape crashes and burns and SSL becomes TLS under auspices of IETF

Certificates are fundamental to SSL and TLS



11

~~Machine~~ Man in the Middle Attack (MitM)



12

What do Digital Certificates Do?

They certify something, just like a real-life certificate

Two kinds of certificates

- End Entity or Leaf Certificates
 - They certify the authenticity of a Web site, a piece of software, or a user
- Certificate Authority Certificates
 - They certify the authenticity of another certificate



13

What's in a Certificate?

14

What's in a Certificate?

Distinguished Names

- Subject Name
- Issuer Name

Public Key

Digital Signature

Expiration date

Usage flags

Subject Alternative Names (SANs)



Just the main features –
not exhaustive

15

What's in a Certificate? Take a look

If it's installed in RACF

- RACDCERT LIST or LISTCHAIN

If it's in an MVS data set

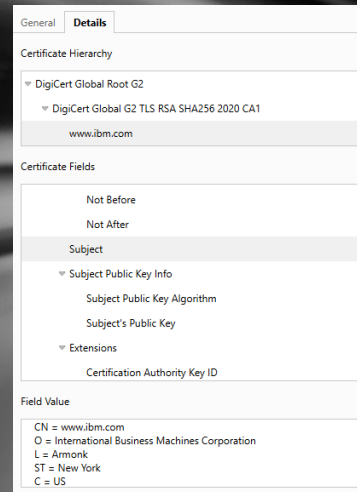
- RACDCERT CHECKCERT(data.set.name)

If it came to your browser from a Web server

- Click icon to the left of the URL, then Connection is secure, then Certificate is valid (exact prompts vary by browser)

If it's in a file on your PC or Linux

- Multiple sites – Google display x.509 certificate
- Remember – certificate data is generally not sensitive



16

Distinguished Names

Subject Name and Issuer Name

You're familiar with how Distinguished Names are displayed:

- CN = www.ibm.com O = International Business Machines Corporation L = Armonk ST = New York C = US

Each component like C=US is called a Relative Distinguished Name (RDN)

RDNs specified in the certificate as "object identifiers" (OIDs)

- Example 1.2.840.113549.1.9.1
- Fascinating topic but beyond the scope of this class. Google if you are interested.

Believe it or not, those RDN tags like CN= are not standardized

- RACF uses SP=, most systems use ST=
- RACF uses T=, most systems use TITLE=

17

Subject Alternative Names (SANs)

Additional Web server names for which certificate valid

- IBM.com certificate lists 65 (July, 2026): myibm.ibm.com, manage.marketplace.ibm.com, partnerportal.ibm.com, ...
- Amazon.com lists 18: amzn.com, iphone.amazon.com, shop.business.amazon.com, ...

Certificate “extension” – not in original standard

Sorry – Certificate Authorities generally charge a lot extra to issue!

18

What's NOT in a Certificate

Private key

- Never!
- Stored securely in software or hardware
- Associated with the certificate by RACF or other certificate management system
- Don't lose it!

Label

- RACF's name FOR the certificate; not a part of the certificate
- USERID/CERTAUTH/SITE

“Whatever you want to put in it”

- No! Rigidly defined by X.509
- Want to include your own text? OU is your friend



Takeaway: The private key is never in a certificate or CSR

19

How Does a Certificate Sign a Certificate?

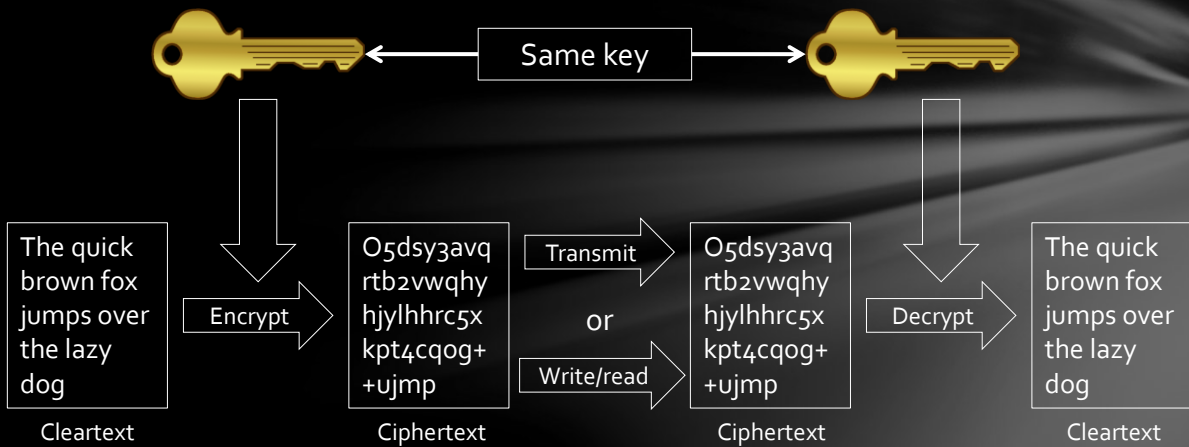
20

How does one certificate sign another?



21

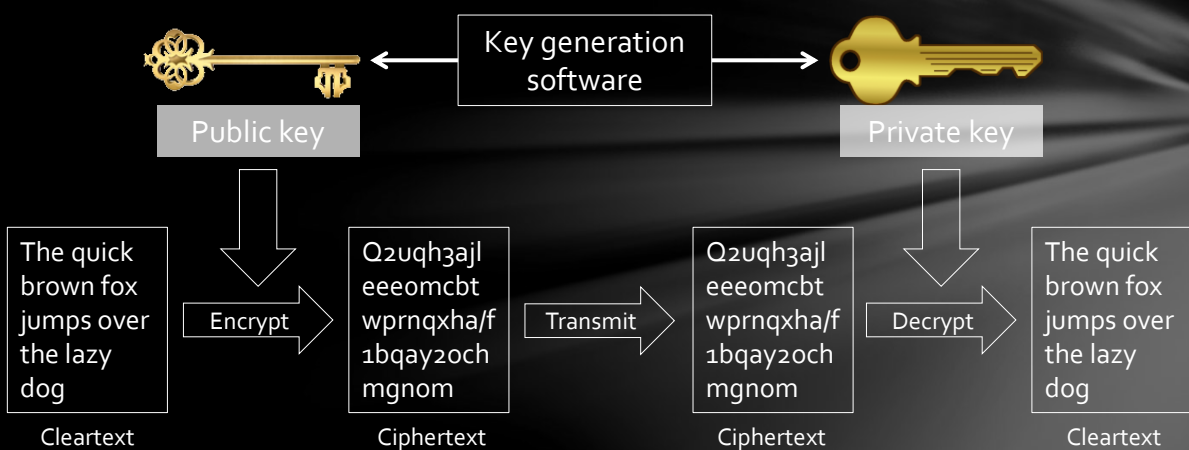
Secret (Symmetric) Key Encryption



<http://bit.ly/2ilor54>

22

Public Key (Asymmetric) Encryption



<http://bit.ly/2io5WvQ>

23

Digital Hash

Function that takes a possibly very long "message" and returns a relatively short fixed-length binary value

Must be relatively easy to calculate

Deterministic: same message yields same hash

Possible but highly unlikely two slightly different messages have same hash

Almost impossible to construct a message with a predictable hash

Same hash = same message

Also called message digest

Examples: SHA-2 (MD5, SHA-1)

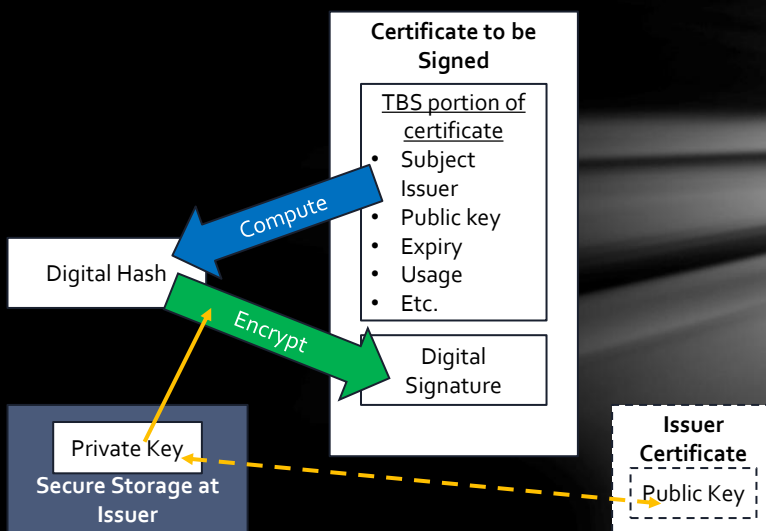
<http://bit.ly/2mNglor>

Message		Resulting Hash or Digest
Fox	cryptographic hash function	DFCD 3454 BBEA 788A 751A 696C 24D9 7009 CA99 2D17
The red fox jumps over the blue dog	cryptographic hash function	0086 46BB FB7D CBE2 823C ACC7 6CD1 90B1 EE6E 3ABC
The red fox jumps over the blue dog	cryptographic hash function	8FD8 7558 7851 4F32 D1C6 76B1 79A9 0DA4 AEFE 4819
The red fox jumps over the blue dog	cryptographic hash function	FCD3 7FDB 5AF2 C6FF 915F D401 C0A9 7D9A 46AF FB45
The red fox jumps over the blue dog	cryptographic hash function	8ACA D682 D588 4C75 4BF4 1799 7D88 BCF8 92B9 6A6C

Source: Wikipedia
By User:Jorge Stolfi based on Image:Hash_function.svg by Helix84 - Original work for Wikipedia,
Public Domain, <https://commons.wikimedia.org/w/index.php?curid=5290240>

24

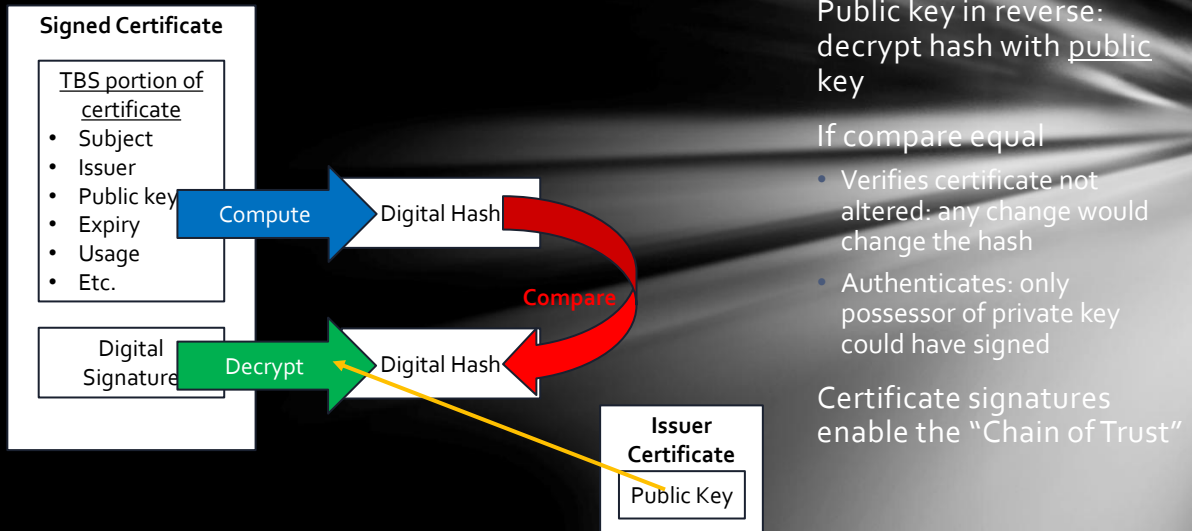
How an Issuer signs a certificate



Public key in reverse:
encrypt hash with private
key

26

How a recipient validates a signature



27

The Chain of Trust

28

End Entity Certificates – how they work

Your client connects to some server

They send you a certificate

If

- The Subject or an Alternative Name matches the server you wanted; and
- The server can prove mathematically that it has the private key that matches the public key in the certificate; and
- Usage includes proper authority, usually TLS Web Server Authentication
- The certificate is not expired; and
- The certificate is not revoked*; and
- The certificate is signed by a certificate you can validate

Then you can trust the authenticity of the server and proceed with the session

*Revocation covered below

29

Certificate Authority Certificates – how they work

Certificate A validates certificate B

If

- The Subject Name of A matches the Issuer Name in B; and
- The public key in A validates the digital signature in B; and
- A's Usage includes Certificate Sign; and
- A is not expired; and
- A is not revoked*; and
 - A is signed by a certificate you can validate; or
 - A is a root certificate that has been marked trusted based on a security management decision

*Revocation covered below

30

Root certificates

The chain has to end somewhere!

Issuer name = Subject name

- Hence "self-signed"
 - It signs itself
 - NOT "we signed it ourselves in-house"

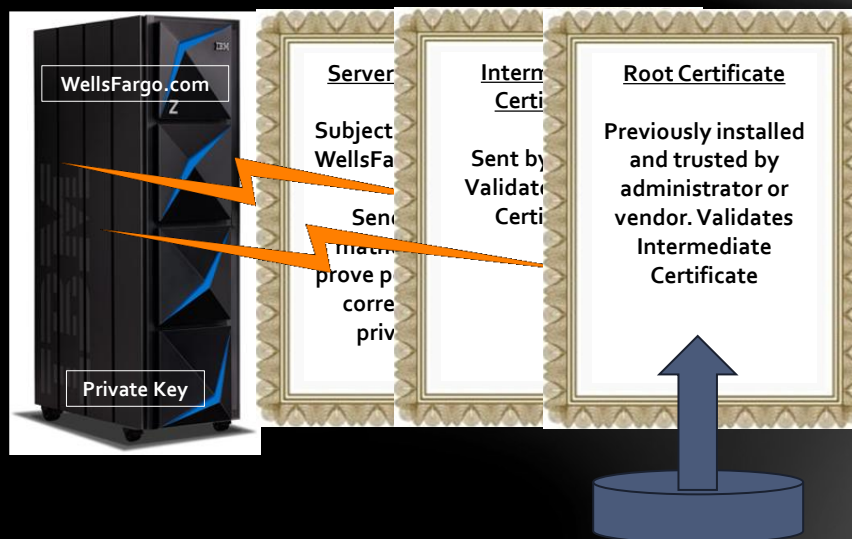
Must be pre-installed at the receiving end (usually the client)

Must be marked "trusted" in the certificate repository

Takeaway: Trusting a root certificate is a security management decision

31

Chain of Trust



32

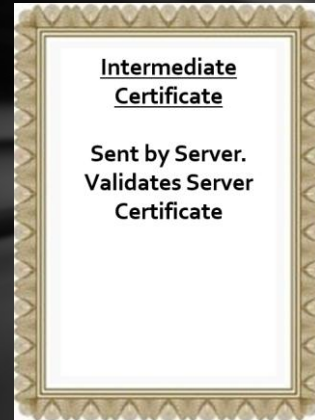
Why Intermediate Certificates?

The compromise of a CA root private key would render root and all certificates issued by CA untrustworthy – a disaster!

Certificate Authorities store their root keys off-line to help prevent compromise

They use medium-term intermediate certificates – signed by their root certificate – to issue end-user certificates

Intermediate certificates sign end-entity certificates and are signed by the root certificate: "Chain of trust"



33

Certificate Issuance, Renewal and Revocation

34

Certificate Authority

Company or group within a company that issues certificates

Uses self-created root certificate to sign them

May be well-known CA (market shares as of July 2026)

- Let's Encrypt – Free! Automated only. 68% market share!
- GlobalSign – 21% market share
- Sectigo (formerly Comodo) – 5% market share
- GoDaddy – 4% market share
- DigiCert – 2% market share
- Symantec, GeoTrust and Thawte – killed by Google, Apple and Mozilla due to compliance failures

Or department or individual

Well-known CA required for public-use SSL/TLS

<http://bit.ly/2oKougM>



35

Self-signed end entity certificates

Can a server certificate also be a root certificate? Yes ...

- Issuer name = Subject name

It is then a one-certificate complete chain of trust

Sufficient to enable TLS encryption

Not considered a security best practice

May be an audit finding

Won't work for public-facing servers and may be difficult to administer

- Every self-signed server certificate must be individually installed and trusted on every relevant client

36

How do you get a CA to issue your certificate?

You use your certificate system to generate a Certificate Signing Request (CSR)

CSR internally has most of the fields of a certificate – but no issuer or digital signature

- No private key so no risk in transmitting

You send the CSR to the Certificate Authority

Most CAs charge a fee from a few dollars to a few thousand dollars

- Let's Encrypt is free but only supports automated requests

CA uses various processes to validate that you are the legitimate owner of the domain in the Subject Name

Then CA issues a certificate signed by a chain of trust ending in their root

- No private keys

37

Certificate Renewal

Certificates expire and must be renewed

Generate CSR from existing certificate

Two approaches

- GENREQ – simpler
- REKEY – more secure, more complex

Industry moving to very short certificate lifetimes so lots of renewals

- 47 days as of March, 2029
- See next slide for reasons

Industry moving to automated renewals

- ACME – Automated Certificate Management Environment
 - Many implementations for Linux and Windows, many of them free
 - Support on z/OS: IBM zSecure Secret Manager and BMC AMI Connector for Venafi (AFAIK)

38

Revocation

Why would a Certificate Authority revoke a certificate?

- Most common reason is issued in error: typo, mistake, unauthorized, ...
- Key compromise
- Major Certificate Authority governance issue

Three (?) standards – all are problematic

“Revocation is Broken” (Scott Helme, 2017 – Google if you are interested)

Current Solution is very short certificate lifetimes – 47 days as of March, 2029

- Punishing the innocent to protect the guilty

39

A Very Brief Introduction to Certificate Management

40

PEM Format Certificate Files

A self-identifying ("BEGIN CERTIFICATE") format using printable characters

RACF calls it CERTB64

No private key!

Easier to deal with than DER – use PEM any time you can

- Move to or from PC or Linux with editor cut-and-paste (or "ASCII" FTP, etc.)
- Unfortunately, totally impossible for a human to read

-----BEGIN and END CERTIFICATE----- are part of the format – don't forget them

There are free Web DER/PEM conversion tools – Google is your friend

CSRs are always PEM – copy and paste into CA Web site

- -----BEGIN NEW CERTIFICATE REQUEST-----

```
***** Top of Data *****
-----BEGIN CERTIFICATE-----
MIIFazCCA1OgAwIBAgIRAIQz7DSQONZRGFGu20C1wAwDQYJKoZI
TzELMAkGA1UEBhMCVVMxKTAnBgNVBAoTIEludGVybWV0IFN1Y3Vz
cmNoIEdyb3VwMRUwEwYDVQQDEwVJU1JHIFJvbnR3QWUwEwYDVQ
WWhcNMzUwNjA0MTEwNDM4VjBPMDQwQWUwEwYDVQDEwVJWUzEpMCCGA1U
ZKQgU2VjdXJpdHkgUmVzZWZyY2ggR3JvdXAxFTATBgNVBAMTE1
MTCCAI1wDQYJKoZIhvcNAQEBBQADggIPADCCAgcCggIBAK3oJHP
h77ct984kIzuPOZXoHj3dcKi/vVqbwYATyjb3miGbESTtrFj/RQ
0TM8ukj13Xnfs7j/EvEhmkvBioZxaUpmZmyPffjxwv60pIgbz5MD
A5/TR5d8mUgjU+g4rk8Kb4Mu0U1XjIB0ttov0DiNewNwIRt18jA
T8KOEUT+zvvv/7V3LvSye0rgTB1LDHCNAymg4VMk7BPZ7hm/ELN
B5T0Y3HsLuJvW5iB4Y1cNH1sdu87kGJ55tukmi8mxdAQ4Q7e2RC
B5iPngiV5+I3lg02dZ77DnKxHZu8A/LJBdiB3QW0KtZB6awBdpU
KBds0ppjBqAlkd25HN7rOrFleaJ1/ctaJxQZBKT5ZPt0m9STJEad
01FuhjuefXKnEgV4We0+UXgVCwOPjdAvBbI+e0ocS3MFEvzG6uB
jh8BCNAw1FtxNrQHusEwMFxIt4I7mKZ9YIqioymCzLq9gwQbocM
qHyG00aoSCqI3Haadr8faqU9GY/rOPNk3sgrDQoc/fb4hVC1CL
rU7m2Ys6xt0nUW7/vGT1M0NPAgMBAAGjQjBAMA4GA1UdDwEB/wQ
HRMBaf8EETADAQH/MB0GA1UdDgQWBBER5tFnme7b15AFzgAiiYBp
hkiG9w0BAQsFAAOCAgEAVR9YqbyyqFDQDLHYGmkGjYkIrGF1XIP
ubhzEFnTIzd+50xx+7LSYK05qAvqFyFWhfFQDlnrzuzBZ6brJFe+
3BebYhtF8G6V0nxvvuo77x/Py9auJ/GpsMiu/X1+mvoiB0v/2K/c
NftY2PwByVS5uCbMioGziUwthDyC3+6WVwW6LLv3xLfHTjuCvjH
ORAZI4JMPJ+Gs1WYHb4phowim57iaztX0cJwTdw34nLCgdNbOh
TkXWStAmzOVyyghqZKjFaH3pO3JLF+1+/sKAiuvtd7u+Nxe5A
jNPElpzVmbUq4JUagEiutDkHszHpFKVK7q4+63SM1N95R1NbdW
oyi3B43njTOQ5yOf+iCceWxG1bQV6sZufpM1jq4Uio/1lvh+wj
4RgqahDYVvTH9w7jXbyLeiNdd8XM2w9U/t7y0Ff/9yi0GE44Za
mGunUHBcnWEvgJBQ19nEiU0Zsnvgc/ubhPgXRR4Xq37Z0j4r7
emyFwgcYxn/eR44/KJ4EBs+1VDR3veyJm+kXQ99b21/+jh5Xos1
-----END CERTIFICATE-----
***** Bottom of Data *****
```

43

PKCS12

Package that includes certificate and private key

- Must be protected by password
- Possibly not a best practice – passwords are problematic
- RACF will not create PKCS12 export for keys stored in hardware (ICSF)
- May contain one certificate or entire chain
- RACF supports DER and PEM PKCS12 files
- Windows calls them .PFX files

44

Other certificate file types

PKCS7 – package of multiple certificates – typically an entire chain of trust

- RACF supports DER or PEM

PKCS8 or .key – not supported by RACF

PKCS stands for Public Key Cryptography Standard

45

Some Certificate Problems

46

Some Certificate Problems

Complexity

Certificate management

- Especially expiration

Key management

- Keeping private keys private
- But not losing them!

CA Root Certificates and Trust

"Revocation is Broken"

Quantum is coming ...

Certificate Authority Issues

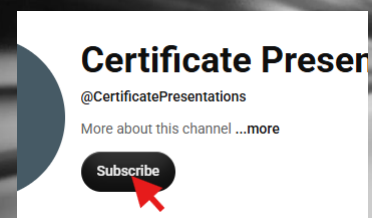
- Repressive government pressures CA to facilitate Man-in-the-Middle
- Dutch CA DigiNotar hacked; fraudulent Google.com certificate used for Man-in-the-Middle interception of Iranian citizens <https://bit.ly/3hN1b2n>
- Name validation by CA
 - Requirement for CA to validate URLs at odds with modern certificate volumes
 - In March of 2017, Google announced Chrome would stop honoring Symantec certificates for (among other things) sloppiness in validating certificate names <https://bit.ly/2QG5lxd>
 - Death penalty! Symantec sold CA business to DigiCert
 - "Extended Validation" of little value <https://bit.ly/36HQaPi>
- Any CA can issue a certificate for any site!

47

Like this webinar? There are 3 more ...

1. Introduction to Digital Certificates
2. The TLS Protocol – An Inside View
3. Introduction to Certificate Management with RACF
4. Some Advanced Digital Certificate Topics

X.509 and ASN.1. X9. Base 64. Quantum. The coming 47-day renewal crisis and ACME. Client certificates. Cross-signing. Code signing. Validated boot.



https://www.youtube.com/channel/UC_d8Tscv3tmS2AfIPvzRPhA
<https://bit.ly/3TZcTz4>

<https://bit.ly/3TZcTz4>

48

Thank you

Questions? Comments?
charlesm@mcn.org